

VulnGuard 安全扫描报告

2026/6/12 10:41 · 引擎: AI 智能

扫描目标 D:\DEMO\aut\data\uploads\upload-1781232116496-aqsb	扫描 ID scan-1781232117085-w7ng	风险评分 F
文件检测数 172	漏洞总数 12	扫描日期 2026/6/12 10:41
风险评分 ● 有风险	严重 2	高危 3
中危 7	低危 0	检测总数 172

🔍 扫描器执行结果

✔ Gitleaks 密钥检测 完成 发现 4 个问题	⚠ pip-audit 依赖扫描 失败 pip-audit not found	✔ npm audit 依赖扫描 完成
✔ Bandit 静态代码分析 完成	✔ Trivy 文件系统 完成	✔ AI Scanner AI 分析 完成 发现 8 个问题
✔ Nuclei 文件系统 完成		

📄 漏洞发现详情 (12)

Critical		2 项
#1 多个扫描器存在OS命令注入		
位置	aut/src/lib/scanner/bandit.ts:72, aut/src/lib/scanner/bearer-scanner.ts:50, aut/src/lib/scanner/checkov.ts:62	
描述	在bandit.ts、bearer-scanner.ts和checkov.ts中，执行扫描命令时直接将用户控制的targetPath拼接到shell命令字符串中，未进行转义或使用数组参数。攻击者可通过构造恶意路径注入任意系统命令，导致远程代码执行。	
修复建议	使用child_process.spawn或execFile，将参数作为数组传递，避免shell解释。同时对所有路径参数进行严格的合法性校验。	
CVE	CWE-78	

#2 删除扫描会话接口未授权访问

位置	aut/src/app/api/scans/route.ts:39
描述	DELETE /api/scans 端点未进行身份验证，任何未经授权的用户都可以调用该接口清除所有扫描会话和上传文件，导致数据丢失和业务拒绝服务。
修复建议	在 DELETE 方法中添加 requireAuth 调用，与 GET 和 POST 方法保持一致。
CVE	CWE-862

High

3 项

#3 未授权访问与越权操作 (IDOR)

位置	aut/src/app/scan/history/page.tsx:86-93, aut/src/lib/api/client.ts:13-14, aut/src/components/report/DownloadPdfButton.tsx:29
描述	后端API仅依赖全局共享的SCAN_AUTH_TOKEN进行认证，缺乏用户级权限校验。攻击者可以通过已知或猜测的扫描ID，未授权查看、删除其他用户的扫描记录 (IDOR)。前端页面 (如scan/history) 调用了这些未加身份绑定的API，进一步暴露风险。
修复建议	实施基于用户的身份认证和权限控制。每个API请求应关联当前用户，并验证用户是否有权访问资源。移除全局共享令牌，改用session或JWT绑定用户身份。
CVE	CWE-862

#4 敏感信息泄露 (认证Token在客户端暴露)

位置	aut/src/app/reports/page.tsx:96, aut/src/app/scan/new/page.tsx:38, aut/src/lib/api/client.ts:9, aut/src/components/report/DownloadPdfButton.tsx:27
描述	客户端代码通过NEXT_PUBLIC_SCAN_AUTH_TOKEN环境变量使用认证令牌，该令牌在构建时被内联到客户端JS中。任何用户均可通过查看页面源码或网络请求获取令牌，导致未授权访问后端API (读取扫描详情、删除扫描等)。
修复建议	移除前端直接使用令牌的方式，改用服务器端API代理 (BFF模式)，令牌仅在服务端存储和使用。删除NEXT_PUBLIC_前缀，仅在服务端环境变量中保留。
CVE	CWE-200

#5 缺失认证: /api/llm/analyze 端点

位置	aut/src/app/api/llm/analyze/route.ts:1-77
描述	分析API端点/api/llm/analyze未使用requireAuth中间件进行身份验证，而其他类似端点已正确实施认证。攻击者可未授权调用，消耗DeepSeek API额度，或通过prompt注入影响安全性。
修复建议	在路由处理函数开头添加requireAuth调用。
CVE	CWE-862

Medium

7 项

#6 generic-api-key

位置	D:/DEMO/aut/data/uploads/upload-1781232116496-aqsb/aut/.env.local:5
描述	Detected a Generic API Key, potentially exposing access to various services and sensitive operations.
修复建议	Remove hardcoded credentials from source code. Use environment variables or a secrets manager. Found in D:/DEMO/aut/data/uploads/upload-1781232116496-aqsb/aut/.env.local:5
CVE	CWE-798

#7 generic-api-key

位置	D:/DEMO/aut/data/uploads/upload-1781232116496-aqsb/aut/.env.local:7
描述	Detected a Generic API Key, potentially exposing access to various services and sensitive operations.
修复建议	Remove hardcoded credentials from source code. Use environment variables or a secrets manager. Found in D:/DEMO/aut/data/uploads/upload-1781232116496-aqsb/aut/.env.local:7
CVE	CWE-798

#8 generic-api-key

位置	D:/DEMO/aut/data/uploads/upload-1781232116496-aqsb/aut/.env.local:8
描述	Detected a Generic API Key, potentially exposing access to various services and sensitive operations.
修复建议	Remove hardcoded credentials from source code. Use environment variables or a secrets manager. Found in D:/DEMO/aut/data/uploads/upload-1781232116496-aqsb/aut/.env.local:8
CVE	CWE-798

#9 private-key

位置	D:/DEMO/aut/data/uploads/upload-1781232116496-aqsb/aut/tools/nuclei-templates/file-misconfig.yaml:45
描述	Identified a Private Key, which may compromise cryptographic security and sensitive data encryption.
修复建议	Remove hardcoded credentials from source code. Use environment variables or a secrets manager. Found in D:/DEMO/aut/data/uploads/upload-1781232116496-aqsb/aut/tools/nuclei-templates/file-misconfig.yaml:45
CVE	CWE-798

#10 Redis未设置密码认证

位置	aut/docker-compose.yml:8-18
描述	Redis服务未配置密码认证，且6379端口暴露到宿主机。攻击者若可访问该端口，可无需认证直接连接Redis，执行任意命令，导致缓存数据泄露或篡改。
修复建议	设置requirepass密码；避免端口映射到0.0.0.0；使用Redis ACL限制命令。
CVE	CWE-306

#11 认证令牌通过查询参数传递

位置	aut/src/lib/api/auth.ts:20
描述	服务器端requireAuth函数允许通过URL查询参数?token=传递令牌。查询参数可能记录在服务器日志、浏览器历史或Referer头中，增加令牌泄露风险。尽管为支持SSE而设计，但增加了攻击面。
修复建议	避免使用查询参数传递敏感令牌；对SSE场景可考虑WebSocket或POST连接；确保日志不包含查询参数。
CVE	CWE-598

#12 扫描会话文件更新存在竞态条件

位置	aut/src/lib/scanner/scan-store.ts:updateSession
描述	scan-store.ts的updateSession和getSession函数分别执行文件读写，没有同步机制。多个请求同时更新同一个会话文件可能导致数据覆盖或状态丢失。
修复建议	引入文件锁（如proper-lockfile）确保原子操作，或改用数据库存储会话。
CVE	CWE-362